

TỔNG CỤC II
HỌC VIỆN KHOA HỌC QUÂN SỰ

ĐỀ CƯƠNG SƠ BỘ VỀ SÁNG KIẾN
BỘ CÔNG CỤ BẢO ĐẢM AN TOÀN THÔNG TIN VÀ QUYỀN RIÊNG
TƯ DỮ LIỆU TRÊN THIẾT BỊ DI ĐỘNG (SECUREVAULT MOBILE)

Hà Nội, năm 2026

ĐỀ CƯƠNG SƠ BỘ VỀ SÁNG KIẾN

Bộ công cụ bảo đảm an toàn thông tin và quyền riêng tư dữ liệu trên thiết bị di động (SecureVault Mobile)

Về tài liệu này. Đề cương sơ bộ được lập ở giai đoạn đặt vấn đề, nhằm trả lời ba câu hỏi trước khi bắt tay vào làm: *định làm gì, làm theo cách nào, và lấy gì để chứng minh là đã làm được?* Vì hồ sơ được nộp khi công việc đã hoàn thành, mỗi phần kế hoạch dưới đây đều kèm phần đối chiếu với kết quả thực tế — để thấy rõ điều gì diễn ra đúng dự kiến, điều gì phải điều chỉnh, và điều gì đến nay vẫn còn dang dở. Phần diễn giải kỹ thuật ở mức từng cơ chế nằm ở văn bản 05 — Đề cương chi tiết.

MỤC LỤC

Nhấn chuột phải vào đây rồi chọn “Cập nhật trường” để hiện mục lục.

I. LÝ DO ĐỀ XUẤT SÁNG KIẾN

1. Ràng buộc nghiệp vụ — điểm xuất phát

Sáng kiến bắt đầu từ một ràng buộc, không phải từ một ý tưởng công nghệ. Ở Học viện Khoa học Quân sự và các cơ quan, đơn vị có yêu cầu cao về bảo vệ thông tin, việc quản lý, lưu trữ và chuyển giao tài liệu mật, tài liệu nội bộ phải tuân thủ nghiêm ngặt quy định hiện hành; đơn vị *không cho phép* đưa tài liệu mật và tài liệu nội bộ lên thiết bị di động cá nhân.

Ràng buộc đó loại bỏ ngay một hướng đi tưởng như hiển nhiên — làm một ứng dụng để mang tài liệu công tác theo người — và buộc sáng kiến phải tìm giá trị ở chỗ khác. Việc xác định ranh giới này ngay từ đầu, thay vì để lộ ra khi đã làm xong, là quyết định đầu tiên và cũng là quyết định định hình toàn bộ phần còn lại.

2. Hai nhu cầu thực tiễn nằm trong ranh giới cho phép

Nhu cầu thứ nhất — huấn luyện. Bảo vệ dữ liệu bằng mật mã là nội dung quan trọng trong chương trình đào tạo an toàn thông tin, bảo đảm an toàn tình báo trên không gian mạng. Nhưng việc học hiện nay chủ yếu dừng ở lý thuyết, thuật toán và công cụ chạy trên máy tính, trong khi thiết bị di động mới là môi trường học viên phải bảo vệ dữ liệu nhiều nhất sau khi ra trường. Học viên biết nguyên lý nhưng chưa từng thao tác, chưa từng thấy một hệ thống an toàn hoàn chỉnh vận hành ra sao — đó là khoảng cách cần lấp.

Nhu cầu thứ hai — tình huống khẩn cấp, bất khả kháng. Trong công tác vẫn phát sinh trường hợp một số tài liệu đặc thù buộc phải chuyển gấp qua không gian mạng khi không còn phương án nào khác kịp thời hạn. Tập rời khỏi tầm kiểm soát của người gửi và đi qua hạ tầng không do đơn vị quản lý. Trong những trường hợp đã được cấp có thẩm quyền cho phép chuyển giao, cán bộ cần một công cụ tin cậy và kiểm chứng được để tự trang bị thêm lớp bảo vệ cho tệp trước khi gửi.



Hình 1. Hai nhu cầu thực tiễn mà sáng kiến hướng tới và bốn nhóm nguy cơ tương ứng

3. Vì sao các giải pháp sẵn có chưa lấp được khoảng trống

Sáu nhóm giải pháp đã được khảo sát trước khi quyết định tự xây dựng. Nhận xét rút ra không phải là “các giải pháp hiện có kém” — mỗi nhóm đều làm tốt việc mà nó được thiết kế cho — mà là *không nhóm nào giải quyết trọn vẹn bài toán đang xét*.

Bảng 1. Khoảng trống của từng nhóm giải pháp so với nhu cầu đặt ra

Nhóm giải pháp	Điểm chưa đáp ứng được
Mã hoá toàn thiết bị của hệ điều hành	Chỉ bảo vệ khi máy tắt hoặc chưa mở khoá lần đầu; khi máy đã mở khoá thì mọi ứng dụng đều thấy dữ liệu ở dạng rõ, và tệp rời thiết bị thì không còn được bảo vệ
Ứng dụng “khoá tệp”, “kết riêng tư” trên kho ứng dụng	Phần lớn mã nguồn đóng nên không kiểm chứng được thuật toán và cách quản lý khoá; nhiều ứng dụng đòi quyền mạng; định dạng riêng khoá người dùng vào một sản phẩm
Trình quản lý mật khẩu mã nguồn mở	Thiết kế cho thông tin đăng nhập, không nhằm xử lý tệp, ảnh, tài liệu; không có ký số, kiểm tra toàn vẹn, chia khoá phục hồi hay xử lý siêu dữ liệu
Công cụ mật mã dòng lệnh	Thuật toán tin cậy nhưng không có bản dùng được trên thiết bị di động — lý do kỹ thuật nêu ở mục I.4; giao diện dòng lệnh không phù hợp người dùng không chuyên
Ứng dụng nhắn tin mã hoá đầu-cuối	Bảo vệ đường truyền nhưng không bảo vệ dữ liệu ở trạng thái lưu trên máy; dữ liệu vẫn đi qua hạ tầng của nhà cung cấp dịch vụ nước ngoài
Giải pháp quản lý thiết bị / chống thất thoát dữ liệu	Cần hạ tầng máy chủ, chi phí bản quyền và phụ thuộc nhà cung cấp; khó triển khai cho nhu cầu cá nhân và nhóm nhỏ

4. Rào cản kỹ thuật khiến khoảng trống tồn tại

Câu hỏi tự nhiên là: nếu đã có công cụ mật mã dòng lệnh rất tốt, vì sao không đưa thẳng chúng lên điện thoại? Đây là điểm mấu chốt và cũng là lý do sáng kiến có chỗ đứng.

Các công cụ mật mã tin cậy được phân phối dưới dạng *tệp nhị phân chạy độc lập*. Trên máy tính để bàn, ứng dụng gọi chúng như một tiến trình con: nạp tệp nhị phân, truyền tham số, đọc kết quả. Trên thiết bị di động thì cơ chế đó bị chặn ở hai tầng khác nhau: iOS cấm hoàn toàn việc một ứng dụng sinh tiến trình; Android cho phép sinh tiến trình nhưng chặn thực thi tệp nhị phân nằm trong vùng lưu trữ mà ứng dụng ghi được — tức đúng nơi mà một tệp nhị phân đóng gói kèm ứng dụng sẽ nằm.

Vì sao rào cản này khó phát hiện sớm

Mọi chức năng phụ thuộc tiến trình con sẽ không hoạt động trên điện thoại *kể cả khi mã nguồn biên dịch thành công*. Chương trình dựng xong, cài được, mở được, và chỉ hỏng khi người dùng bấm vào chức năng.

Vì vậy đây là rào cản thuộc về kiến trúc nền tảng, phải giải quyết bằng thiết kế ngay từ đầu, không phải bằng công sức lập trình về sau. Đó là căn cứ cho cách tiếp cận ở Phần III.

II. MỤC TIÊU, ĐỐI TƯỢNG VÀ PHẠM VI

1. Mục tiêu

Mục tiêu tổng quát: xây dựng một bộ công cụ bảo vệ dữ liệu hoạt động hoàn toàn trên thiết bị, vừa dùng được làm học cụ trực quan cho huấn luyện an toàn thông tin, vừa đủ tin cậy để cán bộ trang bị thêm lớp bảo vệ cho tệp trong tình huống khẩn cấp, bất khả kháng đã được cho phép chuyển giao.

Năm mục tiêu cụ thể được đặt ra ngay từ đầu, và mỗi mục tiêu kèm một cách kiểm tra để về sau đối chiếu được:

Bảng 2. Mục tiêu cụ thể và cách kiểm tra tương ứng

Mục tiêu đặt ra	Cách kiểm tra đã dự kiến	Kết quả
Hoạt động hoàn toàn trên thiết bị: không quyền mạng, không tài khoản, không đồng bộ đám mây	Đọc tệp kê khai trong gói cài đặt đã đóng gói	Đạt
Kiểm chứng được: mã nguồn mở, thuật toán công khai, có bộ kiểm thử tự động	Đếm và chạy lại bộ kiểm thử	Đạt — 272 hàm
Gộp nhiều nghiệp vụ bảo vệ dữ liệu trong một ứng dụng thống nhất	Đếm số chức năng nghiệp vụ từ mã nguồn	Đạt — 38 chức năng
Tệp đầu ra theo chuẩn mở, không khoá người dùng vào một sản phẩm	Đối chứng hai chiều với công cụ chuẩn độc lập	Đạt — 5 phép
Dùng được làm học cụ mà vẫn đạt chuẩn kỹ thuật của công cụ dùng thật	Ánh xạ từng nhóm chức năng với nội dung trong chương trình đào tạo	Đạt — bảng ánh xạ tại Phần VIII

Mục tiêu thứ năm đáng chú ý vì nó *thường mâu thuẫn* với bốn mục tiêu còn lại. Sản phẩm dựng riêng để dạy học hay bị đơn giản hoá tới mức không dùng được thật; ngược lại, công cụ chuyên nghiệp lại quá phức tạp cho giờ thực hành. Cách hoá giải mâu thuẫn này được trình bày ở Phần III mục 2 và Phần VIII.

2. Đối tượng phục vụ

- **Giảng viên.** Dùng sản phẩm làm học cụ thực hành trên lớp; mỗi nhóm chức năng minh hoạ một nội dung có sẵn trong chương trình.
- **Học viên.** Thực hành trực tiếp các nội dung mã hoá, chữ ký số, chia sẻ bí mật theo ngưỡng, kiểm tra toàn vẹn, giấu tin và xử lý siêu dữ liệu; đồng thời tự bảo vệ dữ liệu cá nhân để hình thành thói quen nghề nghiệp.

- **Cán bộ trong tình huống khẩn cấp, bất khả kháng.** Khi được phép và buộc phải chuyển giao tài liệu qua không gian mạng, dùng sản phẩm để mã hoá, ký số, kiểm tra toàn vẹn và loại bỏ siêu dữ liệu trước khi chuyển giao.

3. Phạm vi thực hiện và những gì nằm ngoài phạm vi

Xác định rõ cái *không* làm cũng quan trọng như xác định cái sẽ làm — nó giữ cho khối lượng công việc nằm trong tầm và giữ cho hồ sơ không tuyên bố quá phạm vi.

Bảng 3. Phạm vi thực hiện

Trong phạm vi	Ngoài phạm vi
Thiết kế kiến trúc, định dạng tệp dữ liệu và sơ đồ phân cấp khoá	Tự xây dựng thuật toán mật mã mới — dùng chuẩn công khai đã được soi xét
Hiện thực toàn bộ nghiệp vụ bảo vệ dữ liệu trong một lõi độc lập nền tảng	Thay đổi hoặc nói lỏng bất kỳ quy định nào về bảo vệ bí mật
Ứng dụng chạy trên thiết bị di động Android — trọng tâm của sáng kiến	Tuyên bố sản phẩm được phép xử lý tài liệu ở một cấp độ mật cụ thể
Bản trên máy tính để bàn dùng chung lõi, đóng vai trò đối chứng và mở rộng	Đóng gói bản cài đặt có ký số, công chứng để phân phối rộng rãi
Bộ kiểm thử tự động và quy trình nghiệm thu trên thiết bị thật	Bảo vệ dữ liệu khi thiết bị đã bị chiếm quyền điều khiển ở mức hệ điều hành

Phạm vi tự giới hạn

Sáng kiến là công cụ hỗ trợ kỹ thuật nhằm giảm rủi ro trong phạm vi hoạt động đã được phép. Việc một tài liệu cụ thể có được lưu trữ, xử lý hay chuyển giao qua một phương thức nhất định hay không vẫn hoàn toàn do quy định hiện hành và người có thẩm quyền quyết định.

III. Ý TƯỞNG GIẢI PHÁP VÀ CÁCH TIẾP CẬN

1. Ý tưởng cốt lõi

Từ rào cản ở Phần I mục 4, ý tưởng của nhóm tác giả không phải là “tìm cách chạy công cụ dòng lệnh trên điện thoại” — hướng đó bị hệ điều hành chặn và không thể vòng qua. Ý tưởng là *đảo ngược chỗ đặt vấn đề*:

Ý tưởng cốt lõi của sáng kiến

Đưa toàn bộ nghiệp vụ bảo vệ dữ liệu — định dạng tệp, sơ đồ khoá, quy tắc lỗi, các phép mật mã — vào một lõi *độc lập* với *giao diện* và *độc lập* với *nền tảng*.

Đặt điểm nối trùu tượng tại đúng những vị trí phải phụ thuộc nền tảng, và chỉ ở đó.

Khi đổi nền tảng, chỉ thay phần nằm *trên* các điểm nối ấy. Nghiệp vụ, định dạng dữ liệu và cơ chế bảo vệ nằm *dưới* nên giữ nguyên — kể cả khi cách hiện thực bên dưới thay đổi hoàn toàn.

Điểm khó của ý tưởng nằm ở chỗ *đặt điểm nối ở đâu*. Đặt quá cao, ở mức nghiệp vụ, thì mỗi nền tảng phải viết lại toàn bộ nghiệp vụ và hai bản sẽ trôi xa nhau theo thời gian. Đặt quá thấp, ở mức từng phép mật mã, thì mỗi bản hiện thực phải tự ghép lại đúng định dạng tệp và rất dễ lệch. Điểm nối được chọn đặt tại ranh giới “*một luồng dữ liệu vào, một luồng dữ liệu ra theo định dạng công khai*” — nhờ vậy hai bản hiện thực khác nhau hoàn toàn về cách chạy nhưng buộc phải cho ra cùng một chuỗi byte.

2. Sáu nguyên lý được chọn làm ràng buộc thiết kế

Trước khi viết dòng mã đầu tiên, sáu nguyên lý được xác lập. Điều nhóm tác giả coi trọng không phải bản thân các nguyên lý — chúng là hiểu biết chung của ngành — mà là yêu cầu tự đặt ra: *mỗi nguyên lý phải được chuyển hoá thành một ràng buộc kỹ thuật kiểm tra được bằng máy*. Nguyên lý chỉ nằm trong tài liệu thì sớm muộn cũng bị vi phạm khi phần mềm được sửa đổi; nguyên lý có cơ chế kiểm tra thì không.

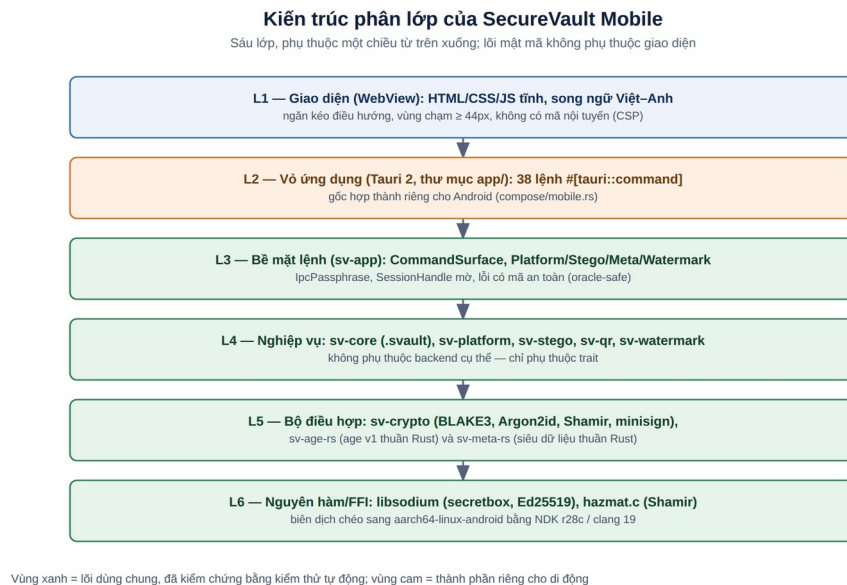
- *Hoạt động ngoại tuyến tuyệt đối* — ứng dụng không khai báo quyền truy cập mạng, nên ràng buộc nằm ở cấp hệ điều hành chứ không phụ thuộc thao tác người dùng.
- *Một lõi bảo vệ dữ liệu dùng chung* — toàn bộ nghiệp vụ mật mã nằm trong lõi, không dùng thư viện giao diện hay thư viện đặc thù nền tảng.
- *Phụ thuộc một chiều theo lớp* — lớp trên dùng lớp dưới, không có chiều ngược lại; lõi chỉ phụ thuộc vào giao diện trùu tượng.
- *Khi không bảo đảm an toàn thì không tiếp tục xử lý* — thà từ chối kèm mã lỗi còn hơn báo thành công cho một việc chưa chắc đã làm được.

- *Thông báo lỗi không làm lộ thông tin bí mật* — chênh lệch giữa các thông báo không được dùng làm tín hiệu dò mật khẩu.
- *Không lưu trữ bí mật lâu dài* — mật khẩu và khoá chính không bao giờ chạm tới bộ nhớ lưu trữ của thiết bị.

Cách chuyển hoá từng nguyên lý thành cơ chế cụ thể và cách kiểm tra tương ứng được trình bày ở mục 2.1 của Đề cương chi tiết.

3. Kiến trúc dự kiến

Ứng dụng được tổ chức thành sáu lớp chức năng, trong đó giao diện tách hẳn khỏi lõi nghiệp vụ: mọi yêu cầu từ giao diện xuống lõi phải đi qua một tập lệnh được kiểm soát thống nhất, không có đường truy cập trực tiếp nào khác. Lõi được chia thành 15 thành phần độc lập, mỗi thành phần một trách nhiệm. Việc chia nhỏ không nhằm cho “gọn” mà để chiều phụ thuộc giữa các thành phần trở thành thứ kiểm tra được bằng máy.



Hình 2. Kiến trúc phân lớp dự kiến của sản phẩm

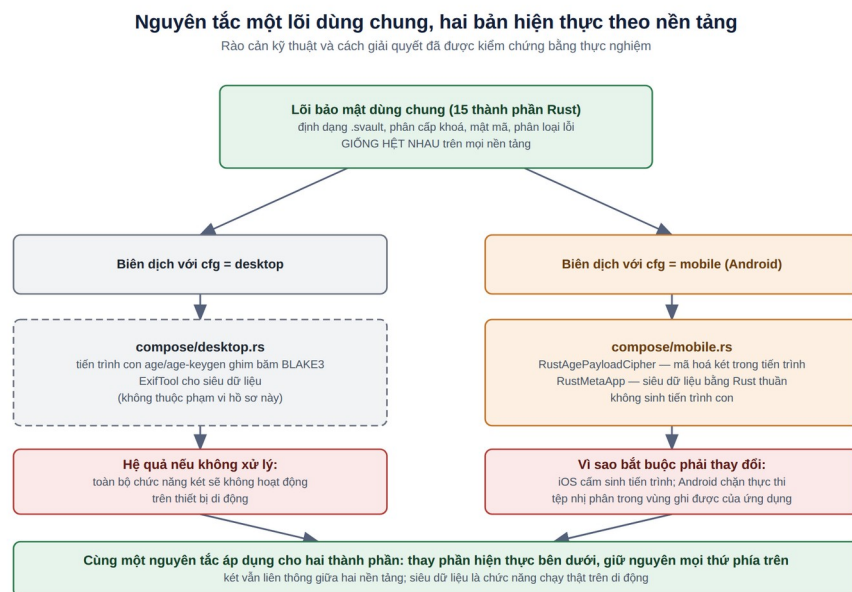
4. Triển khai trên hai nền tảng và vai trò của từng bản

Kiến trúc trên có một hệ quả mà ban đầu không phải là mục tiêu, nhưng về sau trở thành một trong những tính chất đáng giá nhất: *nếu nghiệp vụ và định dạng dữ liệu đều nằm dưới ranh giới không phụ thuộc nền tảng, thì thay nền tảng không còn là viết lại sản phẩm, mà chỉ là thay phần nằm trên ranh giới đó*. Kế hoạch vì vậy đặt ra hai bản hiện thực dùng chung một lõi, với vai trò khác hẳn nhau.

Bảng 4. Vai trò của hai bản trong sáng kiến

	Bản trên máy tính để bàn	Bản trên thiết bị di động
Mô-đun mã hoá nội dung	Điều khiển công cụ chuẩn dưới dạng tiến trình con, có ghim giá trị băm tệp nhị phân	Thực hiện ngay trong tiến trình ứng dụng
Mô-đun siêu dữ liệu	Gọi công cụ ngoài, phạm vi định dạng rộng	Mô-đun thuần Rust do nhóm tác giả viết, phạm vi hẹp và công bố rõ
Bài toán kỹ thuật phải giải	Không có rào cản đặc thù	Rào cản tiến trình con của hệ điều hành di động — trọng tâm của sáng kiến
Vai trò trong hồ sơ	Bản đối chứng và tham chiếu ngữ nghĩa; mở rộng phạm vi sử dụng	Nơi tập trung giá trị sáng tạo
Nghiệp vụ, định dạng tệp, sơ đồ khoá, quy tắc lỗi	Như nhau	Như nhau

Nói ngắn gọn: *bản máy tính chứng minh kiến trúc là đúng, bản di động chứng minh kiến trúc là có ích*. Trọng tâm của sáng kiến nằm ở bản di động, vì đó là nơi rào cản kỹ thuật thực sự tồn tại và được giải quyết.



Hình 3. Nguyên tắc một lỗi dùng chung, hai bản hiện thực theo nền tảng

IV. NỘI DUNG THỰC HIỆN

1. Các khối công việc

Bảng 5. Khối công việc và sản phẩm của từng khối

Khối công việc	Nội dung chính	Sản phẩm của khối
A. Thiết kế nền móng	Xác định mô hình mối đe dọa, sáu nguyên lý thiết kế, ranh giới giữa các lớp và giao diện trừu tượng của các nguyên hàm mật mã	Tài liệu kiến trúc và tập giao diện trừu tượng
B. Thiết kế dữ liệu	Cấu trúc tệp kết, sơ đồ phân cấp khoá, ngữ cảnh dẫn xuất khoá, cơ chế chữ ký ràng buộc phần đầu tệp với nội dung	Đặc tả định dạng tệp và sơ đồ khoá
C. Hiện thực lõi nghiệp vụ	Nghiệp vụ kết, bảo vệ tệp đơn lẻ, ký số và kiểm tra toàn vẹn, chia bí mật theo ngưỡng, giấu tin, thuỷ vân, siêu dữ liệu	Lõi gồm 15 thành phần cùng bộ kiểm thử
D. Quy tắc lỗi và ranh giới lệnh	Phân loại lỗi nội bộ, quy tắc chiếu ra giao diện sao cho không lộ thông tin, mô hình phiên làm việc	Tập 38 lệnh nghiệp vụ có ngữ nghĩa ổn định
E. Bản trên máy tính để bàn	Lớp lắp ráp cho máy tính, giao diện, đóng gói; đóng vai trò bản đối chứng	Ứng dụng chạy trên máy tính
F. Bản trên thiết bị di động	Giải rào cản tiến trình con: bản hiện thực trong tiến trình cho mô-đun mã hoá và mô-đun siêu dữ liệu; luồng tệp theo cơ chế của Android; giao diện cảm ứng	Ứng dụng Android đóng gói được
G. Kiểm chứng	Bộ kiểm thử tự động, kiểm thử trên kiến trúc bộ xử lý của điện thoại, đối chứng với công cụ chuẩn, kiểm tra tính gói cài đặt, quy trình nghiệm thu	Bảng chứng kiểm chứng nhiều mức

2. Các nhóm chức năng dự kiến

Chức năng được nhóm theo *mục đích sử dụng* chứ không theo thuật toán, để người dùng chọn được chức năng mà không cần biết bên trong dùng gì. Tám nhóm dưới đây là kế hoạch ban đầu, và cũng là cấu trúc của sản phẩm cuối cùng với tổng cộng 38 chức năng nghiệp vụ.

Bảng 6. Tám nhóm chức năng và nguyên lý an toàn thông tin tương ứng

Nhóm	Nội dung nghiệp vụ	Số chức năng	Nguyên lý minh hoạ
1. Két an toàn	Một tệp .svault chứa nhiều tệp dưới một mật khẩu; danh mục tệp cũng được mã hoá	12	Dẫn xuất khoá từ mật khẩu
2. Bảo vệ tệp đơn lẻ	Khoá và mở khoá trực tiếp một tệp bằng mật khẩu, không cần lập kết	3	Mã hoá có xác thực
3. Kiểm chứng nguồn gốc và tính toàn vẹn	Chữ ký số, vân tay tệp, đối chiếu vân tay, xác minh tệp tải về	6	Mật mã khoá công khai và hàm băm
4. Sao lưu và khôi phục bằng chia sẻ bí mật theo ngưỡng	Chia bí mật hoặc tệp thành n mảnh, cần đủ k mảnh mới khôi phục; chuyển mảnh qua mã QR	7	Chia sẻ bí mật theo ngưỡng
5. Che giấu dữ liệu trong ảnh và phát hiện dữ liệu ẩn	Giấu tệp đã mã hoá vào ảnh, lấy lại, và phát hiện dấu hiệu dữ liệu ẩn	3	Giấu tin và giới hạn của che giấu
6. Thuỷ vân chống giả mạo ảnh	Nhúng và kiểm tra thuỷ vân dễ vỡ, khoanh vùng vị trí ảnh bị sửa	2	Phát hiện sửa đổi cục bộ trên ảnh
7. Siêu dữ liệu ẩn trong tệp	Xem, xoá và so sánh siêu dữ liệu ngay trên thiết bị, gồm cả toạ độ định vị	4	Kênh lộ thông tin ngoài nội dung
8. Thông tin ứng dụng	Tra cứu phiên bản ứng dụng, giao tiếp lỗi, định dạng kết và bộ thuật toán	1	—

Cột cuối là căn cứ cho mục tiêu thứ năm ở Phần II: mỗi nhóm chức năng gắn với một nội dung có sẵn trong chương trình đào tạo.

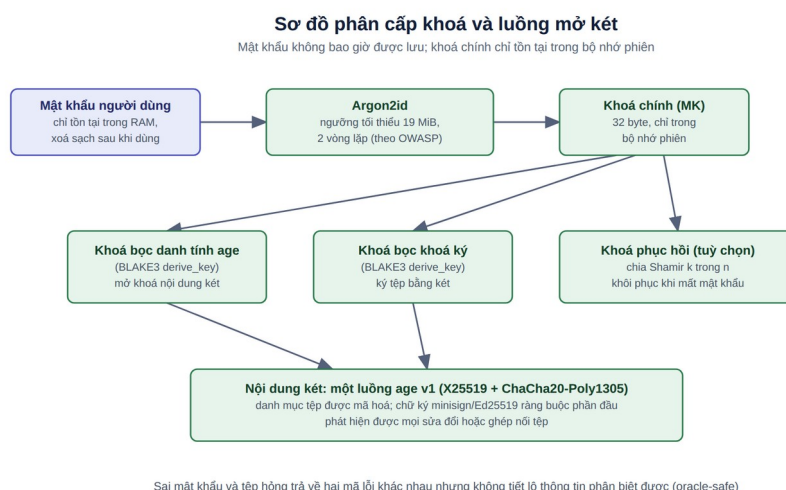
3. Thiết kế dữ liệu và cơ chế bảo vệ

Ba quyết định thiết kế dữ liệu được xác định ngay ở khối công việc B, vì chúng khó sửa về sau: mỗi thay đổi đều làm hỏng những tệp đã tạo trước đó.

- **Danh mục tệp nằm bên trong phần đã mã hoá.** Nhiều định dạng đặt danh sách tệp ở phần đầu cho tiện đọc nhanh; hệ quả là người có tệp mà không có mật khẩu vẫn biết bên trong có những gì. Ở đây toàn bộ nội dung kết, kể cả danh mục, là một luồng mã hoá duy nhất — kết đang khoá không tiết lộ tên tệp, kích thước hay cả số lượng tệp.

- **Khoá chỉ được lưu ở dạng đã bọc, với khoá bọc ràng buộc theo từng trường và từng kết.** Nhờ vậy một khối dữ liệu đã bọc không dùng được cho trường khác, cũng không mang được từ kết này sang kết khác. Một hệ quả thực dụng: đổi mật khẩu chỉ phải bọc lại vài khoá con, không phải mã hoá lại toàn bộ nội dung.
- **Chữ ký phủ lên một “gốc ràng buộc” tính từ cả phần đầu lẫn phần nội dung.** Nhờ vậy không thể ghép phần đầu của tệp này với nội dung của tệp khác. Việc kiểm tra chữ ký diễn ra *trước* khi mật khẩu được dùng đến, nên phân biệt được “tệp hỏng” với “mật khẩu sai” mà không biến sự phân biệt đó thành manh mối dò mật khẩu.

Về nguyên hàm mật mã, nguyên tắc nghề nghiệp được tuân thủ tuyệt đối: *không tự xây dựng thuật toán mới*. Bộ nguyên hàm gồm Argon2id dẫn xuất khoá từ mật khẩu với ngưỡng 19 MiB bộ nhớ và 2 vòng lặp theo khuyến nghị OWASP; BLAKE3 băm nội dung và tạo khoá con theo ngữ cảnh; age v1 (X25519 + ChaCha20-Poly1305) mã hoá nội dung kết; XSalsa20-Poly1305 (libsodium secretbox) bảo vệ các trường khoá; Ed25519 (định dạng minisign) ký phần đầu tệp; và Shamir k-trong-n (sss hazmat.c) chia khoá phục hồi. Đóng góp của nhóm tác giả nằm ở việc chọn nguyên hàm nào cho việc gì, ghép chúng trong một kiến trúc, và đặt tham số phù hợp với ràng buộc của thiết bị di động.



Hình 4. Sơ đồ phân cấp khoá và luồng mở kết

4. Yêu cầu đặt ra cho giao diện

Với một ứng dụng bảo vệ dữ liệu, một thao tác sai vì giao diện gây hiểu nhầm cũng dẫn tới lộ dữ liệu như một lỗi mật mã. Vì vậy giao diện được xem là một phần của thiết kế an toàn, với bốn yêu cầu đặt ra từ đầu: trình bày theo *công việc cần làm* chứ không theo thuật toán; phân tầng thông tin để người dùng mới không bị ngợp mà

người muốn kiểm chứng vẫn đủ dữ kiện; cảnh báo liên quan đến nguy cơ mất dữ liệu thì *không được thu gọn*; và không để kết quả của thao tác trước bị hiểu nhầm là kết quả của thao tác mới.

V. PHƯƠNG PHÁP VÀ KẾ HOẠCH KIỂM CHỨNG

1. Nguyên tắc kiểm chứng

Nguyên tắc đặt ra cho toàn bộ công việc: *mỗi tuyên bố kỹ thuật trong hồ sơ phải gắn với một cách kiểm tra bằng máy, và phải phân biệt rõ giữa “đã hiện thực” với “đã kiểm chứng bằng thực nghiệm”*. Hai điều đó khác nhau, và việc gộp chúng lại là cách phổ biến nhất khiến một hồ sơ kỹ thuật mất tin cậy. Nguyên tắc này cũng áp dụng cho chính hồ sơ: mọi con số trong các văn bản đều được sinh tự động từ mã nguồn và nhật ký kiểm thử.

2. Các mức kiểm chứng và kết quả

Bảng 7. Kế hoạch kiểm chứng và kết quả thực tế

Mức	Cách làm	Tiêu chí đạt	Kết quả
1. Kiểm thử đơn vị và tích hợp	Bộ kiểm thử tự động chạy trên máy chủ tích hợp liên tục	Không có phép kiểm thử nào lỗi	263 đạt / 0 lỗi
2. Đúng kiến trúc bộ xử lý của điện thoại	Chạy lỗi dưới trình giả lập kiến trúc ARM64 trên mã đã biên dịch cho kiến trúc đó	Các thành phần mật mã và lớp gọi thư viện hệ thống chạy đúng	146 đạt / 0 lỗi
3. Đa nền tảng	Dựng, soát mã và chạy kiểm thử trên ma trận hệ điều hành (Windows, macOS, Linux)	Mọi hạng mục đều xanh trên cả ba hệ điều hành	9 hạng mục đạt (2026-06-15)
4. Tương thích định dạng	Đối chứng hai chiều với công cụ chuẩn độc lập và mở chéo kết giữa hai bản hiện thực	Cả hai chiều đều đọc được tệp của nhau; mật khẩu sai vẫn bị từ chối	5 phép đối chứng đạt
5. Kiểm tra gói cài đặt	Mở gói cài đặt sẽ giao cho người dùng và đọc nội dung bên trong	Đúng kiến trúc thư viện; không khai báo quyền mạng; giao diện nhúng sẵn	Đạt
6. Nghiệm thu trên thiết bị thật	Quy trình 15 bước có tiêu chí đạt cho từng bước	Từng bước đạt tiêu chí đã ghi	Chưa thực hiện — đã có quy trình

3. Kiểm chứng tương thích giữa các nền tảng

Trong sáu mức trên, mức 4 đáng nói riêng vì nó kiểm chứng đúng tuyên bố trung tâm của kiến trúc. Ràng buộc tự đặt ra là: *dù thay bản hiện thực nào bên dưới, định dạng tệp trên đĩa không được thay đổi*. Đây là loại ràng buộc dễ bị vi phạm âm thầm

— một thay đổi nhỏ có thể sinh ra tệp mà chỉ chính nó đọc được — và không thể phát hiện bằng cách đọc mã.

Vì vậy kế hoạch đặt ra hai loại phép kiểm chứng. Loại thứ nhất đối chứng với *công cụ chuẩn do bên thứ ba viết*: tệp do sản phẩm tạo phải giải mã được bằng công cụ đó và ngược lại — khi đó kết luận về tính tương thích không còn phụ thuộc vào lời khẳng định của nhóm tác giả. Loại thứ hai dựng nguyên một tệp kết hoàn chỉnh bằng bản hiện thực của nền tảng này rồi mở bằng bản của nền tảng kia, đi qua toàn bộ chuỗi từ dẫn xuất khoá tới giải mã danh mục và lấy tệp ra. Cả hai loại đã thực hiện: 5 phép, tất cả đạt.

4. Phần chưa kiểm chứng

Nêu rõ thay vì bỏ qua

Nghiệm thu trên thiết bị Android thật chưa thực hiện tại thời điểm lập hồ sơ. Mọi kiểm chứng đều trên máy chủ, kể cả phép chạy dưới trình giả lập kiến trúc ARM64. Quy trình nghiệm thu 15 bước đã soạn sẵn tại Phụ lục A của Đề cương chi tiết.

Việc đóng gói bản cài đặt có ký số và công chứng cho Windows và macOS chưa thực hiện, nên hồ sơ không tuyên bố sản phẩm đã sẵn sàng phát hành trên hai nền tảng đó; điều được khẳng định là mã nguồn dựng và chạy kiểm thử đạt trên các nền tảng đó.

VI. SẢN PHẨM VÀ CHỈ TIÊU

1. Danh mục sản phẩm

- Ứng dụng Android đóng gói dưới dạng APK (42,3 MB), tích hợp lỗi bảo vệ dữ liệu biên dịch cho kiến trúc ARM64.
- Mã nguồn đầy đủ: lỗi gồm 15 thành phần độc lập, giao diện gồm 21 màn hình, kèm 272 hàm kiểm thử tự động.
- Bản trên máy tính để bàn dùng chung lỗi, dựng và chạy kiểm thử đạt trên Windows, macOS, Linux.
- Bộ tài liệu: tài liệu kiến trúc, mô hình mối đe dọa, hướng dẫn triển khai và quy trình nghiệm thu trên thiết bị thật.

2. Chỉ tiêu đặt ra và kết quả đạt được

Bảng 8. Đối chiếu chỉ tiêu dự kiến với kết quả thực tế

Chỉ tiêu	Dự kiến ban đầu	Đạt được	Cách xác định
Số chức năng nghiệp vụ	Đủ cho tám nhóm nghiệp vụ	38 chức năng	Đếm trực tiếp từ mã nguồn
Chức năng chưa có giao diện gọi tới	Không có	0	Đối chiếu hai chiều giữa lỗi và mã giao diện
Số hàm kiểm thử tự động	Đủ phủ từng thành phần	272 hàm	Đếm trực tiếp từ mã nguồn
Quyền ứng dụng yêu cầu	Không quyền nào	Không khai báo quyền nào	Đọc tệp kê khai trong gói cài đặt
Tương thích định dạng	Đọc được cả hai chiều	5 phép đối chứng đạt	Đối chứng với công cụ chuẩn độc lập
Chạy trên hệ điều hành máy tính	Cả ba hệ điều hành phổ biến	Windows, macOS, Linux — đạt	Biên bản tích hợp liên tục 2026-06-15
Nghiệm thu trên thiết bị Android thật	Có quy trình và thực hiện	Đã có quy trình 15 bước, chưa thực hiện	Phụ lục A của Đề cương chi tiết

VII. TIẾN TRÌNH THỰC HIỆN

Công việc được chia thành các giai đoạn theo thứ tự phụ thuộc: giai đoạn sau chỉ bắt đầu khi giai đoạn trước đã chốt được thứ mà nó cần. Toàn bộ quá trình diễn ra trong khoảng từ 2026-06-15 đến 2026-09-10, ghi nhận qua lịch sử kho mã nguồn.

Bảng 9. Các giai đoạn thực hiện

Giai đoạn	Nội dung	Điều kiện để chuyển giai đoạn
Nền móng	Chốt giao ước giữa các lớp, giao diện trừu tượng của nguyên hàm mật mã, mô hình mối đe dọa và sáu nguyên lý thiết kế	Giao diện trừu tượng đủ để lỗi kiểm thử được độc lập với bản hiện thực thật
Nguyên hàm mật mã	Hiện thực và kiểm thử từng nguyên hàm; chốt chính sách tham số	Từng nguyên hàm có kiểm thử riêng và đối chiếu với vector chuẩn
Định dạng dữ liệu và phân cấp khoá	Chốt cấu trúc tệp kết, ngữ cảnh dẫn xuất khoá, cơ chế chữ ký ràng buộc	Định dạng được coi là đóng băng — mọi thay đổi về sau đều phá vỡ tệp cũ
Nghiệp vụ và ranh giới lệnh	Hiện thực các nghiệp vụ; chốt quy tắc phân loại lỗi và mô hình phiên làm việc	Tập lệnh có ngữ nghĩa ổn định để giao diện dựa vào
Bản trên máy tính và làm cứng	Lớp lắp ráp cho máy tính, giao diện, đóng gói; rà soát và khắc phục các điểm yếu phát hiện qua thực nghiệm	Bộ kiểm thử xanh trên ma trận ba hệ điều hành
Bản trên thiết bị di động	Giải rào cản tiến trình con; mô-đun mã hoá và mô-đun siêu dữ liệu chạy trong tiến trình; luồng tệp theo cơ chế Android; giao diện cảm ứng; đóng gói APK	Tệp kết đọc chéo được giữa hai nền tảng; gói cài đặt kiểm tra tĩnh đạt
Kiểm chứng và lập hồ sơ	Chạy kiểm thử trên kiến trúc ARM64, đối chứng định dạng, kiểm tra gói cài đặt, soạn quy trình nghiệm thu và bộ hồ sơ sáng kiến	Mọi số liệu trong hồ sơ sinh tự động từ mã nguồn và nhật ký

Một điều chỉnh đáng kể so với kế hoạch ban đầu cần được ghi nhận: nhóm mô-đun siêu dữ liệu ban đầu dự kiến dùng lại cách làm của bản máy tính. Khi triển khai lên di động mới phát hiện cách đó vướng đúng rào cản đã nêu ở Phần I mục 4, nên phải bổ sung một khối công việc không có trong kế hoạch: tự viết mô-đun xử lý siêu dữ liệu bằng Rust. Đây cũng là ví dụ cho thấy vì sao rào cản đó khó lường trước.

VIII. DỰ KIẾN HIỆU QUẢ, RỦI RO VÀ KHẢ NĂNG ÁP DỤNG

1. Hiệu quả đối với công tác huấn luyện

Ở Phần II đã nêu mâu thuẫn giữa “dùng được để dạy” và “dùng được thật”. Cách hoá giải là *không dựng hai sản phẩm*: học viên thực hành trên đúng công cụ được xây dựng cho nhu cầu sử dụng thật. Điều làm cho nó dùng được trong dạy học không phải sự đơn giản hoá, mà là bốn yêu cầu giao diện ở Phần IV mục 4 — đặc biệt là phân tầng thông tin: phần kỹ thuật không bị bỏ đi mà đưa vào mục mở rộng, nơi giảng viên mở ra đúng lúc cần giảng.

Một giá trị huấn luyện nữa ít gặp ở công cụ thương mại: sản phẩm *chủ động dạy về giới hạn của chính nó*. Chức năng phát hiện dữ liệu ẩn không kết luận “ảnh sạch” mà chỉ nêu mức độ nghi ngờ trong phạm vi các phép kiểm tra đã làm; chức năng kiểm tra thuỷ văn phân biệt “ảnh bị sửa” với “ảnh đã bị biến đổi khi lưu ở định dạng có mất dữ liệu”. Học viên qua đó hiểu rằng kết quả của một công cụ phân tích luôn phụ thuộc phương pháp và phạm vi — một bài học khó truyền đạt bằng lý thuyết.

2. Hiệu quả kỹ thuật, kinh tế và quốc phòng – an ninh

- **Kỹ thuật.** Bảo vệ dữ liệu ở trạng thái lưu trữ bằng một lớp mật khẩu riêng, kể cả khi thiết bị đã mở khoá; duy trì bảo vệ sau khi tệp rời thiết bị; phát hiện sửa đổi bằng chữ ký số; khôi phục quyền truy cập bằng chia khoá theo ngưỡng mà không phải gửi khoá cho bên thứ ba; loại bỏ siêu dữ liệu ngay tại nơi nó phát sinh; và dùng định dạng mở nên liên thông được với công cụ sẵn có.
- **Kinh tế.** Không phát sinh chi phí bản quyền, không đầu tư máy chủ, không thuê bao dịch vụ, chạy trên thiết bị sẵn có. Nhóm tác giả không quy đổi thành con số tiền cụ thể vì con số đó phụ thuộc quy mô triển khai và chính sách mua sắm của từng đơn vị; ước lượng khi chưa triển khai sẽ không có căn cứ.
- **Quốc phòng – an ninh.** Giảm rủi ro lộ lọt trong tình huống đặc thù đã được cho phép chuyển giao; tăng khả năng kiểm soát dữ liệu vì toàn bộ xử lý diễn ra trên thiết bị; giảm phụ thuộc vào giải pháp bên ngoài vì thiết kế và mã nguồn do đơn vị làm chủ; và góp phần đào tạo nhân lực làm chủ công nghệ.

3. Rủi ro đã lường trước và cách xử lý

Một đề cương trung thực phải nêu cả những rủi ro có thể làm hỏng kết quả. Bảng dưới ghi các rủi ro được nhận diện từ đầu, cách xử lý đã chọn và trạng thái hiện nay.

Bảng 10. Rủi ro, cách xử lý và trạng thái

Rủi ro	Cách xử lý đã chọn	Trạng thái
Rào cản tiến trình con khiến	Đặt điểm nổi trườ tượng và	Đã xử lý; kiểm chứng bằng

chức năng mật mã không chạy trên di động	viết bản hiện thực chạy trong tiến trình	đối chứng định dạng
Thay bản hiện thực làm đối định dạng, tệp cũ không mở được	Đặt bất biến định dạng thành ràng buộc bắt buộc và kiểm chứng bằng thực nghiệm hai chiều	Đã xử lý
Người dùng quên mật khẩu, dữ liệu không lấy lại được	Cung cấp cơ chế chia khoá phục hồi theo ngưỡng; hiển thị cảnh báo thường trực, không thu gọn	Đã giảm thiểu; vẫn là giới hạn có chủ ý của thiết kế
Giao diện hứa nhiều hơn khả năng thật của mô-đun siêu dữ liệu trên di động	Công bố phạm vi định dạng theo đúng nền tảng đang chạy; từ chối kèm mã lỗi với định dạng ngoài phạm vi	Đã xử lý
Thông báo lỗi trở thành manh mối dò mật khẩu	Quy tắc chiếu lỗi từ lỗi ra giao diện, áp dụng thống nhất cho cả hai bản hiện thực	Đã xử lý; có kiểm thử đối chiếu
Số liệu trong hồ sơ lệch với sản phẩm thực tế	Sinh toàn bộ số liệu tự động từ mã nguồn và nhật ký kiểm thử	Đã xử lý
Hành vi trên máy thật khác với môi trường kiểm thử	Soạn quy trình nghiệm thu 15 bước có tiêu chí đạt cho từng bước	Còn tồn tại — quy trình đã có, chưa thực hiện
Thiết bị bị chiếm quyền điều khiển ở mức hệ điều hành	Nằm ngoài khả năng của biện pháp trong phạm vi ứng dụng; công bố rõ trong mô hình mối đe dọa	Chấp nhận, có công bố

4. Khả năng áp dụng và hướng phát triển

Điều kiện triển khai rất đơn giản: một thiết bị Android, không cần máy chủ, không cần kết nối mạng, không yêu cầu quyền quản trị thiết bị — hệ quả trực tiếp của nguyên lý hoạt động ngoại tuyến. Nhờ kiến trúc dùng chung, cùng bộ chức năng còn triển khai được trên máy trạm và tệp kết đi lại được giữa hai môi trường, mở thêm cách dùng thực tế cho công tác giảng dạy.

Hướng phát triển tiếp theo, xếp theo thứ tự ưu tiên:

- Thực hiện quy trình nghiệm thu trên nhiều dòng điện thoại và phiên bản Android khác nhau, ghi nhận kết quả để đánh giá mức độ ổn định.
- Hoàn thiện khâu đóng gói có ký số và công chứng cho bản trên máy tính — bước duy nhất còn thiếu để bản đó phân phối được rộng rãi.
- Nghiên cứu dùng kho khoá phần cứng của thiết bị cho một số khoá nằm ngoài hệ thống khoá của kết, kèm tùy chọn xác thực bằng vân tay.
- Mở rộng phạm vi định dạng của mô-đun siêu dữ liệu, giữ nguyên tắc chỉ báo thành công khi kết quả đã được kiểm tra.

- Biên soạn bộ bài giảng và phiếu bài thực hành đi kèm, làm cơ sở đưa sản phẩm vào chương trình huấn luyện chính thức.

IX. TÀI LIỆU THAM KHẢO

- RFC 9106 — Argon2 Memory-Hard Function for Password Hashing.
- OWASP Password Storage Cheat Sheet — tham số tối thiểu cho Argon2id (19 MiB bộ nhớ, 2 vòng lặp).
- RFC 8439 — ChaCha20 and Poly1305 for IETF Protocols.
- RFC 7748 — Elliptic Curves for Security (trao đổi khoá X25519).
- RFC 8032 — Edwards-Curve Digital Signature Algorithm (chữ ký Ed25519).
- A. Shamir, “How to share a secret”, Communications of the ACM, 1979.
- BLAKE3 — đặc tả hàm băm mật mã và dẫn xuất khoá theo ngữ cảnh.
- Đặc tả định dạng age v1 — định dạng tệp mã hoá mở.
- Android Developers — Storage Access Framework và Scoped Storage.
- Đặc tả Exif 2.32 (CIPA DC-008) — cấu trúc siêu dữ liệu trong tệp ảnh.

Các văn bản khác của hồ sơ: 02 — Thuyết minh sáng kiến (bản cô đọng để đọc nhanh) và 05 — Đề cương chi tiết về sáng kiến (diễn giải kỹ thuật đầy đủ, mô tả từng chức năng kèm giao diện, ảnh chụp toàn bộ màn hình và quy trình kiểm thử nghiệm thu).

Hà Nội, ngày 09 tháng 9 năm 2026

XÁC NHẬN CỦA ĐƠN VỊ

CHỦ NHIỆM SÁNG KIẾN

Thượng úy Trần Thị Tới